Relatório Assignment #1 – Fundamentos de Segurança Informática

Realizado por:

Gustavo Roberto
2023215017

Teodoro Maques
2023211717

1 2 9 0

UNIVERSIDADE D
COIMBRA

1. Descrição das Configurações e Implementação da Arquitetura

A infraestrutura laboratorial foi construída sobre o VMware, utilizando a funcionalidade de "LAN Segments" para garantir o isolamento físico virtual das redes e evitar interferências com o exterior.

A topologia baseou-se numa máquina CentOS 9 Stream a atuar como Router e Firewall central, equipada com múltiplas interfaces de rede e dividida em três zonas lógicas:

- **Interface Externa (ens33):** Configurada com o IP público 87.248.214.97, garantindo acesso à Internet através de NAT.
- **Rede DMZ (ens36):** Estabelecida na rede 23.214.219.128/25, alojando serviços expostos publicamente (DNS, SMTP, WWW) sem necessidade de SNAT.
- **Rede Interna (ens37):** Estabelecida no endereçamento privado 192.168.10.0/24, isolada do exterior.

O roteamento de pacotes foi ativado no *kernel* do Linux (IP Forwarding) e a arquitetura de segurança foi implementada através de um script automatizado (firewall.sh). A firewall foi desenhada com base numa filosofia de segurança máxima (*default-deny*), aplicando a política DROP nas *chains* genéricas INPUT, FORWARD e OUTPUT. Para além do carregamento de módulos como o nf_conntrack_ftp, implementámos regras *stateful* (ESTABLISHED, RELATED) para otimizar o fluxo de conexões de retorno. A comunicação da rede interna isolada para a Internet foi garantida através da configuração de *Source NAT* (Masquerade) na *chain* POSTROUTING.

Para a prevenção de intrusões, instalámos o Suricata (versão 8.0.4). A integração desta ferramenta com o IPTables foi feita através da criação da *chain* SURICATA_INSPECT. Inserimos a regra no topo do roteamento (iptables -I FORWARD 1), garantindo que todo o tráfego a atravessar a firewall é redirecionado para a fila do *kernel* (NFQUEUE num 0). Desta forma, o Suricata atua em modo *in-line* como barreira de inspeção profunda antes de a firewall permitir o pacote.

2. Descrição dos Ataques e Prevenção (IDS/IPS)

Para cumprir os requisitos de proteção, foram configuradas regras customizadas no ficheiro local.rules do Suricata para intercetar três ameaças específicas:

- **Port Scanning:** Técnica de reconhecimento onde múltiplos pacotes SYN são enviados para mapear serviços vulneráveis. A nossa regra (sid:1000005) utiliza o parâmetro threshold. Se o Suricata contabilizar mais de 10 pacotes com a flag SYN provenientes da mesma origem num intervalo de 10 segundos, o tráfego é bloqueado por ser classificado como varrimento agressivo.
- **SQL Injection (SQLi):** O atacante insere código SQL em inputs para manipular ou extrair dados. A nossa regra (sid:1000003) inspeciona o conteúdo do payload à procura das *strings* UNION e SELECT. Ao detetar esta sintaxe combinada, aplica a ação de bloqueio.
- **Cross-Site Scripting (XSS):** Injeção de scripts maliciosos *client-side* (ex: JavaScript). A nossa regra (sid:1000004) analisa o tráfego à procura da *tag* <script>. Ao ser detetada, o IPS descarta o pacote de imediato.

3. Testes e Validação da Solução

A validação da infraestrutura foi realizada através de testes sequenciais rigorosos.

3.1. Validação do Routing e Firewall Inicialmente, testámos a política restritiva executando comandos ping para o Router; o resultado foi 100% de *packet loss*, validando o bloqueio por defeito. O funcionamento do NAT de saída foi validado através de pings da máquina interna para endereços externos públicos, confirmando a tradução de endereços correta. Validámos também que, com o processo do Suricata desligado, os pacotes ficam integralmente retidos na NFQUEUE,

interrompendo o tráfego. Com o motor iniciado (suricata -q 0), a comunicação volta a fluir, provando que o tráfego está verdadeiramente condicionado ao veredicto do IPS.

3.2. Validação do IPS e Ataques Simulados

A partir da máquina atacante (192.168.10.10), simulámos os três ataques requeridos. Para evitar falsos negativos causados por falhas na resolução DNS ou quebras prematuras no *3-way handshake* do TCP (que levariam o Suricata a descartar a análise HTTP), utilizámos os seguintes métodos focados em injeção direta:

1. **Teste de Port Scan:** Executámos um ciclo nativo em Bash (for port in {80..100}; do ...) visando o IP 34.223.124.45. A firewall bloqueou as conexões rápidas sucessivas.
2. **Teste SQLi:** Para garantir a entrega e inspeção do *payload* bruto, injetámos a *string* UNION SELECT diretamente num pacote UDP direcionado ao exterior (8.8.8.8).
3. **Teste XSS:** Pelo mesmo método UDP, enviámos um pacote contendo a *tag* <script>alert('xss')</script>.

Prova de Eficácia: A análise do ficheiro de registo /var/log/suricata/fast.log na Firewall comprovou o sucesso absoluto do sistema. O Suricata intercetou os três vetores de ataque em tempo real, gerando os respetivos alertas (como visível na figura).

Testes iniciais de conectividade (Ping/ICMP) e o registo do primeiro ataque do guião detetado com sucesso pela firewall: o **Port Scanning** (via TCP).

```
[root@a23-214-219-254 benini]# sudo tail -n 10 /var/log/suricata/fast.log
03/22/2026-13:37:05.408168  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-13:37:06.408061  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-13:37:07.425815  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-16:15:46.150029  [**] [1:1000005:1] ALERTA IPS - Port Scanning [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:43382 -> 34.223.124.45:92
```

Registo final e completo, onde já aparecem as deteções dos dois ataques que faltavam: o **SQL Injection** e o **XSS** (que foram enviados via UDP para garantir a leitura imediata dos pacotes maliciosos).

```
[root@a23-214-219-254 benini]# sudo tail -n 10 /var/log/suricata/fast.log
03/22/2026-13:37:05.408168  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-13:37:06.408061  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-13:37:07.425815  [**] [1:1000002:2] ALERTA IPS - Tentativa de SQL Injection/Ping [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:8 -> 192.168.10.254:0
03/22/2026-16:15:46.150029  [**] [1:1000005:1] ALERTA IPS - Port Scanning [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:43382 -> 34.223.124.45:92
03/22/2026-16:19:08.553186  [**] [1:1000003:3] ALERTA IPS - SQL Injection Attack [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.10:56262 -> 8.8.8.8:80
03/22/2026-16:19:13.580268  [**] [1:1000004:3] ALERTA IPS - XSS Attack [**] [Classification: (null)] [Priority: 3] {UDP} 192.168.10.10:40118 -> 8.8.8.8:80
```